shiftflow セキュリティシート

使うサービス・預かる情報・漏洩対策の一覧(2026年11月時点。くわしくはリポジトリの SECURITY.md)

1. 使うサービスと、預ける情報・守り方

サービス	使い道	預ける情報	漏洩対策
Supabase	データベース・ログイン・サーバーの処理・アプリ内のカレンダー(写真の保管も)	社員番号・名前・区所・PIN・勤務の番号とメモ・マスタ・アプリ内のカレンダーの予定と写真・カレンダーID(Google連携の人だけ)	本人の行しか読み書きできない(RLS)。PINは暗号化(ハッシュ)だけ保存。勤務の中身・カレンダーの予定と写真・カレンダーIDは管理者にも見えない
Google カレンダー(連携・任意。Google Cloud のサービスアカウント)	他のカレンダーアプリ・家族に同期したい人だけ、勤務の予定を書き込む	勤務の予定(番号・時刻・泊地)	初期設定は連携なし(Googleに何も送らない)。連携する人も、自分で共有したカレンダーにだけ書く。メインのカレンダーは使えない。共有はいつでも止められる
Google ログイン(かんたん設定・連携する人だけ)	カレンダーを自動で作る	保存しない	権限はアプリが作ったカレンダーだけ(calendar.app.created)。許可は使い終わりにすぐ取り消す
GitHub Pages	画面(Webページ)の公開	なし(画面のプログラムだけ)	パスワード・キーなどの秘密の値はリポジトリに書かない
Claude(写真取込・任意)	勤務指定表の画像の読み取り	画像は本人の Claude アカウントへ送られる	shiftflow のサーバーには画像を送らない。取り込むのは本人の行(行路番号)だけ
Discord	管理者への通知(お問い合わせ・ロック)	お問い合わせの内容	通知先の URL は秘密の値として管理。90日で削除
Gmail・Google Apps Script	お問い合わせのメール返信	メールアドレス・内容・画像	専用アカウントで扱う。合言葉で確かめる。画像は位置情報を消す。90日で削除
cron-job.org	データベースの停止を防ぐ(6時間ごと)	なし	公開用のキーだけ使う。個人情報は扱わない

2. 漏洩対策のチェックリスト

- ✓ ログイン: 社員番号(7桁)+PIN(4桁)。5回失敗で15分ロック。PINを24時間に20回間違えると24時間ロックし、管理者に通知
- ✓ 新規登録: 共通パスワードを知っている人だけ。共通パスワードは暗号化(ハッシュ)だけ保存し、管理画面から変えられる
- ✓ 管理画面: 管理用パスワード(12文字以上)で入る。管理者にも PIN・勤務の中身・カレンダーの予定と写真・カレンダーIDは見えない
- ✓ 外に出さない: 初期設定はアプリ内のカレンダーだけで使い、勤務は Google に送らない。Google連携は、他のカレンダーに同期したい人だけ
- ✓ 通信: すべて HTTPS(暗号化された通信)
- ✓ 必要最小限: 預かるのは勤務の入力・カレンダーの表示に要る情報だけ。広告・分析には使わず、第三者に渡さない
- ✓ 秘密の値: 鍵・パスワードは Supabase・GitHub の秘密の設定にだけ置く。漏れた疑いがあれば作り直す

3. 保存期間(自動で削除)

情報	削除のタイミング
勤務の記録	毎日、13か月前の月の1日より前のぶんを削除(Google カレンダーに登録した予定は消えない)
アプリ内のカレンダーの予定・スタンプ	毎日、12か月前の月の1日より前のぶんを削除
予定に付けた写真	予定が終わって1か月で削除(「画像」に置いた画像は1人10枚まで。本人が消す)
ログイン失敗の記録	30日以上更新がないと削除
お問い合わせ(内容・メール・画像・通知)	最後のやり取りから90日で削除
古いマスタ(前のダイヤ)	次のマスタの切替日が13か月前の月の1日以前になったら削除
利用者	退職・異動などで使わなくなったら、管理者が管理画面で削除(カレンダーの予定・写真も一緒に消える)

4. 事故が起きたとき

①止める: 漏れた鍵・パスワード・通知先の URL を無効にして作り直す
②範囲を調べる: ログインの記録・サーバーのログ・変更の履歴で、何が見えた可能性があるかを調べる
③知らせる: 影響のある利用者に、分かっていること・直したこと・お願い(PINの変更など)を伝える
④直して残す: 原因を直し、再発防止の手当てを記録する

※shiftflow の勤務は会社の正式な記録ではありません。勤務は会社の勤務表で確認してください。問題を見つけたときは、アプリの「お問い合わせ」から「セキュリティの件」と書いて連絡してください。